

SECURITY BUG IN ESP CHIPS!

What Is It? How To Handle It?

NIDHI AGARWAL AND
ASHWINI KUMAR SINHA



Tarlogic Security has uncovered a hidden functionality in the ESP32, a widely used microcontroller that supports Wi-Fi and Bluetooth connectivity in millions of IoT devices. This undocumented feature, if exploited, could allow attackers to impersonate legitimate devices and install persistent malware on critical systems, including smartphones, computers, smart locks, and medical equipment. By bypassing standard code audit controls, malicious actors could potentially compromise sensitive devices at scale.

Cybercriminals could exploit these hidden commands to conduct impersonation or spoofing attacks. By creating fake Bluetooth

devices that mimic legitimate ones, attackers could trick users into connecting, allowing them to intercept keystrokes, passwords, banking details, and personal messages. Beyond data theft, unauthorised remote control of devices is also a concern, with attackers potentially activating microphones or cameras unnoticed. The risk extends beyond smartphones and laptops—digital door locks and medical devices could be compromised.

Espressif, the manufacturer of the ESP32, acknowledges the existence of these hidden commands but states that they are intended for debugging purposes. According to the company, these commands are part of the host controller interface (HCI) protocol used